

TYPE 2

READINESS & REFERENCE

SOC 2 Type 2

An attestation of whether your controls were **suitably designed and operated effectively** across an observation period — the period, how the auditor samples, the recurring evidence to collect, exceptions, and bridge letters.

Observation period

3–12 MONTHS

Operating effectiveness

OVER TIME, NOT A SNAPSHOT

Sampling

ACROSS THE WHOLE WINDOW

Annual renewal

ROLLING 12-MONTH COVERAGE

Framework basis: AICPA TSP Section 100 — Trust Services Criteria (2017, with 2022 revised points of focus); SOC 2 examination guidance under AT-C 205. • **Prepared:** 30 July 2026 • Internal readiness aid.

1 — What a Type 2 report is

A Type 2 report evaluates both the **suitability of design** and the **operating effectiveness** of controls **across an observation period** (commonly 3–12 months). It answers: "Did the controls operate effectively, every time they were supposed to, throughout the window?"

The rule that defines Type 2: a single point-in-time snapshot is **not** enough. The auditor samples evidence drawn from across the whole period to confirm each control operated **consistently** — not just at the start or end. This is why recurring, dated evidence is the heart of a Type 2.

Type 2 vs Type 1 at a glance

Dimension	SOC 2 Type 2	SOC 2 Type 1
Question answered	Did controls operate effectively across a period?	Are controls suitably designed & implemented as of a date?
Time coverage	Observation period (3–12 months)	Point-in-time ("as of [date]")
What's tested	Design plus operating effectiveness over time	Design suitability + implementation on the date
Evidence needed	Recurring evidence spanning the whole period	Current-state snapshot per control
Auditor methods	Inquiry, observation, inspection, reperformance + sampling	Inquiry, observation, inspection, walkthroughs
Report Section IV	Controls plus auditor tests, results, and any exceptions	Lists controls tested — no test results columns
Typical timeline	~6–15 months (includes the observation period)	~3–6 months
Best when	Enterprise buyers require sustained assurance; renewals	Prove design quickly; interim step before Type 2

Many teams issue a Type 1 first. The Type 1 attests the same controls are designed correctly on day one and gives an auditor-signed document to share with customers *while* the Type 2 observation period runs. The controls examined for the Type 1 are the same ones the Type 2 then observes operating.

2 — The observation period

The observation period is the defining feature of a Type 2 — the window over which the auditor evaluates whether controls actually operated, not just whether they were designed well.

Decision	Guidance
How long	Typically 3–12 months. A first Type 2 is often 3–6 months ; renewals move to a rolling 12-month window so coverage is continuous.
When to start the clock	Only after controls are genuinely live and producing evidence. Starting early — while controls are partially in place — means the auditor samples from a window when they were not operating consistently, producing exceptions.
Choosing the window	Avoid ending during holidays, fiscal year-end, or peak cycles. Leave 1–2 weeks between period end and audit kickoff to compile final evidence.
Report validity	The clock starts aging the day the window closes . Plan the renewal before the first report is delivered so there is always a current report available.

3 — How the auditor tests operating effectiveness

On top of the Type 1 design methods (inquiry, observation, inspection), a Type 2 adds **reperformance** and, above all, **sampling** across the period.

Sampling — how it works

Auditors do not test every transaction. They select a **representative sample** from across the observation period; sample size depends on the control's **frequency** and **risk**, and is the auditor's judgment. Illustratively: a control that runs monthly across a 6-month window → typically **2–4 months** sampled; a daily control → a handful of days; a **quarterly** access review across 12 months → the auditor expects to see **all four** reviews, with dates, reviewers, and outcomes.

Exceptions & the auditor's opinion

Concept	What it means
Exception / deviation	Recorded when a control did not operate effectively for some portion of the period (e.g. a missing quarterly review, an access not removed timely, a change deployed without approval).
Impact on opinion	A small number of isolated exceptions does not necessarily cause a qualified opinion; significant or pervasive exceptions can. Address exceptions promptly with corrective action.
Opinion types	Unqualified (clean), Qualified (one or more criteria not fully met), Adverse (controls not effective), or Disclaimer (insufficient evidence to opine).

4 — What's inside a Type 2 report

Same four sections as a Type 1, but Section IV is substantially richer: it adds the auditor's test procedures, the results, and any exceptions for every control.

§	Section	What it contains
I	Independent auditor's opinion	The CPA's opinion on whether, throughout the period , the description is fairly presented and controls were suitably designed and operated effectively .
II	Management's assertion	Management's written assertion covering the description and control effectiveness across the period.
III	System description	Scope, boundaries, infrastructure, software, people, data, and relevant policies for the period.
IV	Criteria, controls, tests & results	The in-scope criteria and controls, plus the auditor's tests, the results, and any exceptions for each control. This is the section that differs most from a Type 1.

5 — The Type 2 roadmap

A first Type 2 typically runs 6–15 months end-to-end, because the observation period itself is part of the timeline.

PHASE 1

Readiness

1–3 months

Scope, implement controls, write policies, assign owners, close gaps. Optionally issue a Type 1.

PHASE 2

Observation period

3–12 months

Controls run; recurring evidence is collected continuously across the window.

PHASE 3

Fieldwork

3–6 weeks

Auditor samples evidence across the period, reperforms, and evaluates effectiveness.

PHASE 4

Report

2–6 weeks

Auditor drafts and issues the report with opinion, tests, results, and exceptions.

The cadence rule: every recurring control needs an **owner**, a **calendar entry**, and a **default evidence destination** (a folder, ticket queue, or tagged channel). If the artifact does not land somewhere consistent as it is produced, the last month of the window becomes a scramble to reconstruct it — the most common source of exceptions.

6 — Recurring evidence — by Trust Services Criteria

Organized by the criteria series in AICPA TSP Section 100. Unlike a Type 1 snapshot, each item must be produced **repeatedly across the period** and is what the auditor samples. Security (CC1–CC9) is mandatory; the other categories appear only when in scope. "Frequency" is the typical control cadence — the auditor samples accordingly.

Criteria series	Typical cadence	Recurring evidence the auditor samples across the period
CC1 — Control Environment	Annual / per-hire	Training completions for staff onboarded or refreshed during the period; policy acknowledgements for new hires.
CC2 — Communication & Info	Ongoing	Evidence policies were communicated; the system description kept current; internal / external reports issued in the period.
CC3 — Risk Assessment	Annual / on change	Risk assessment(s) performed and dated within the period; risk register updates on significant changes.
CC4 — Monitoring	Periodic	Internal reviews / self-assessments; each vulnerability scan or pen test run in the period; deficiency-tracker updates.
CC5 — Control Activities	Ongoing / annual	Evidence control activities operated; policy reviews / re-approvals dated in the period.
CC6 — Logical & Physical Access	Per-event / quarterly	Provisioning & deprovisioning tickets for each joiner / leaver (auditor samples terminations and checks timely removal); every periodic access review with dates & reviewers; MFA enforced throughout; physical-access logs.
CC7 — System Operations	Continuous / per-event	Monitoring & alerting active throughout; scan reports each cycle; incident tickets with response & recovery; incident-response exercise.
CC8 — Change Management	Per-change	The full population of production changes; auditor samples changes and checks approval, testing, and review for each.
CC9 — Risk Mitigation	Annual / periodic	BC/DR test performed in the period; vendor reviews / re-assessments dated in the period; current insurance.
A1 — Availability (if in scope)	Continuous / per-run	Capacity monitoring throughout; backup success logs sampled across the period; restore / DR test record dated in the period.
C1 — Confidentiality (if in scope)	Per-event	Secure-disposal / deletion records for the period; sample of retention-driven disposals.
PI1 — Processing Integrity (if in scope)	Continuous / per-run	Input / processing / output / storage controls operating; reconciliations across the period (auditor samples transactions).
P1–P8 — Privacy (if in scope)	Per-event / ongoing	Consent records; DSAR (access / correction) requests handled in the period with SLA tracking; complaint / disclosure logs.

7 — Common Type 2 pitfalls, bridge letters & renewal

- **Starting the period too early:** opening the window before controls are consistently live guarantees the auditor samples a gap — a false economy that costs more in exceptions than it saves in weeks.
- **Controls implemented mid-period:** evidence won't exist for the portion before a control went live, and the auditor records a deviation. Have controls running before the clock starts.
- **Reconstructed evidence:** artifacts assembled at the last minute rather than captured as produced — the sign of an immature program and a magnet for exceptions.
- **High-frequency exception areas:** quarterly access reviews (all must be present), timely deprovisioning, change approvals, and — if Availability is in scope — an untested DR / incident-response exercise.
- **Letting the report age out:** the window closes and no renewal is planned, leaving a coverage gap.

Bridge (gap) letters. A bridge letter is a short, **management-signed** statement (typically CEO / CTO / CISO) affirming **no material changes** to the control environment between the report's period-end and the next report. It covers the interim gap and is usually accepted for **3–6 months**. It is **not audited**, and the audit firm will **not** issue it — their responsibility ends when the period closes. A bridge letter is not a substitute for a current Type 2.

Renewal cadence. Most organizations move to a **rolling 12-month** observation window after the first report so a current report is always on the shelf. Plan the renewal **before** the first report is delivered — the most expensive renewal is the one that starts after the report has already aged out.

Authoritative sources: AICPA *TSP Section 100 — Trust Services Criteria* (2017, with 2022 revised points of focus) for the criteria; SOC 2 examination performance & reporting guidance under the AICPA attestation standards (AT-C 205). Criteria references were verified against the primary TSP Section 100 text.

This document is an internal readiness aid. It does not constitute an audit opinion, certification, or legal advice. Only a licensed CPA firm can perform a SOC 2 examination and issue a report.